Five security questions, answered

Smart Contract Auditor · EVM · Concrete failure modes

AUD-I-02 | Intermediate | Knowledge

What is a signature replay attack and how can it be prevented?

Answer

Signature validity alone does not make an action one-use. Enforce a consumed nonce and the correct signing domain.

Slither reports patterns to investigate

AUD-F-02 Foundation Knowledge

What is"slither" and what kind of issues can it find?

Answer

A Solidity/Vyper static analyzer. It flags reentrancy, tx.origin authorization and unchecked calls. Review each finding; a clean run does not prove safety.

Credit what the contract receives

AUD-I-01 | Intermediate | Debugging

You are auditing a simple staking contract. What is the first thing you check for regarding the ERC-20 token being staked?

Answer

Transfer fees and rebases. For supported fee-on-transfer tokens, credit the received balance delta. Rebases need separate accounting or explicit rejection.

The balance-delta pattern assumes compatible token behavior and safe call handling; it is not universal support for arbitrary tokens.

Validity, domain, nonce, deadline

AUD-I-02 | Intermediate | Knowledge

What is a signature replay attack and how can it be prevented?

Answer

Reusing a valid signed action. Sign and consume a nonce, bind the domain to chainId and verifyingContract, and enforce a deadline. EIP-712 alone does not prevent reuse.

Fuzzing a custody vault

AUD-A-02 | Advanced | Practical

What is fuzzing (or property-based testing) in the context of smart contracts? Name a tool used for it.

Answer

Generated inputs test properties. Echidna fuzzes call sequences; Foundry supports fuzz and invariant tests. Example for a simple custody vault: assets must cover recorded liabilities.

Passing a finite campaign is not proof of correctness; results depend on the property, harness, inputs and explored state.

A free read still has execution limits

AUD-E-02 | Expert | Architecture

Describe how"unbounded loops" in view functions can become a vector for a Denial of Service (DoS) attack, even if they don't consume transaction gas.

Answer

eth_call executes on an RPC node and can hit gas caps or timeouts. A getAllOwners() that grows forever can fail. Return bounded pages instead.